

CYBERSECURITY

The CIA Triad

The CIA triad is a fundamental model in information security that stands for Confidentiality, Integrity, and Availability. These three principles form the cornerstone of any effective security program. Let's explore each component in detail:

Confidentiality

Confidentiality means **keeping data a secret from everyone except those who we want to access it**. The ISO/IEC 27000:2018 defines it as "The property that information is not made available or disclosed to unauthorized individuals, entities, or processes." In practice, confidentiality ensures that sensitive information is protected from unauthorized access or disclosure. This is often achieved through mechanisms like encryption, access controls, and secure communication channels.

Integrity

Integrity ensures that data **hasn't become corrupted, tampered with, or altered in an unauthorized manner**. The ISO/IEC 27000:2018 defines it as "The property of accuracy and completeness." Maintaining data integrity means ensuring that information remains accurate, consistent, and trustworthy throughout its life-cycle. This is often achieved through methods such as hashing, digital signatures, and version control systems.

Availability

Means that data is **readily accessible to authorized parties when they need it**. The ISO/IEC 27000:2018 defines it as "The property of being accessible and usable upon demand by an authorized entity." Ensuring availability involves implementing robust systems, backup solutions, and disaster recovery plans to prevent disruptions and maintain access to critical information and services.

Organizations must also consider legal and geopolitical factors like [data sovereignty and data residency](#) when designing secure, compliant systems that maintain data availability across regions.

When To use the CIA Triad

You should use the CIA triad in the majority of security situations, particularly because each component is critical. However, it is particularly helpful when developing systems around [data classification](#) and managing permission and access privileges. Stringent employment of the CIA triad when addressing the cyber vulnerabilities of your organization is encouraged. It can be a powerful tool in [disrupting the cyber kill chain](#), especially when combined with [threat modeling](#), which helps security teams map out potential attack paths and assess risk across confidentiality, integrity, and availability. The CIA security triad can help you hone in on what attackers may be after and then implement policies and tools to adequately protect those assets.

In addition, the CIA triad can be used [when training employees regarding cybersecurity](#). You can use hypothetical scenarios or real-life case studies to help employees think in terms of the maintenance of confidentiality, integrity, and availability of information and systems.

Challenges of Adopting the CIA Triad in Cybersecurity

- **Handling massive data:** Securing vast amounts of data from numerous sources in multiple formats is challenging for organizations. Duplicate datasets and disaster recovery processes can increase costs and complicate data protection under CIA.
- **Weak data stewardship and governance:** Big data environments often lack strong auditing and visibility. This leads to poor data stewardship.
- **IoT privacy and security gaps:** IoT devices transmit fragmented data that can compromise user privacy when aggregated. These devices often go unpatched or use weak passwords. This creates new entry points for cyberattacks.
- **Security during product development:** Network-connected products should consider security from the design phase to limit attack surfaces. Failing to do so increases risks to sensitive information across interconnected systems.
- **Balancing usability and security:** Stronger security controls can reduce system availability and frustrate users, leading to workarounds. On the other hand, relaxing security for ease of use can expose systems to breaches.

Implementing the CIA Triad: Best Practices for Cybersecurity

- **Categorize and protect sensitive data:** Classify all data and assets based on their confidentiality needs. Enforce data encryption, [two-factor authentication](#), and maintain updated access control lists and file permissions as part of essential security hygiene.
- **Strengthen role-based privacy training:** Conduct regular privacy awareness training for employees. Tailor sessions to both organization-wide privacy standards and role-specific data management requirements.
- **Implement data integrity controls:** Use version control, data logs, checksums, and hash functions to monitor and preserve data accuracy during processing, transfer, and storage. Apply granular access control to prevent unauthorized data modifications.
- **Adhere to the compliance standards:** Review regulatory obligations. For instance, under the [general data protection regulation \(GDPR\)](#), ensure that data transfers to third-party vendors meet “adequate levels of protection” and are supported by “legal safeguards.”
- **Ensure continuous availability and recovery:** Design systems with redundancy and failover mechanisms to reduce downtime. Use network/server monitoring tools and maintain cloud-based backup. This can help ensure quick and complete data recovery and business continuity in case of a security breach.

2. Defense in Depth

This is the "onion" approach. Since no single security measure is foolproof, you layer multiple defenses so that if one fails, others are there to stop the intruder.

- **Physical Layer:** Guards, locks, and cameras.
- **Network Layer:** Firewalls and encryption.
- **Host Layer:** Antivirus and patch management.
- **Data Layer:** Encryption at rest.

3. The Principle of Least Privilege (PoLP)

This is all about "need to know." A user or system should only have the minimum levels of access—or permissions—needed to perform its job.

- **Why it matters:** If a standard employee's account is hacked, the damage is limited because they don't have administrative "keys to the kingdom."

MALWARE THREATS

1. Primary Classes of Malware

Malware is generally categorized by how it spreads and its primary "payload" (the harmful action it performs).

The "Travelers" (How they spread)

- **Viruses:** Attach themselves to legitimate files or programs. They require human intervention (like opening an email attachment) to execute and spread.
- **Worms:** Self-replicating programs that spread across networks automatically without human help. They exploit system vulnerabilities to move from one machine to another.
- **Trojans:** Disguise themselves as useful software. Once installed, they open a "backdoor" for attackers. Unlike viruses, they don't self-replicate; they rely on deception.

The "Workers" (What they do)

- **Ransomware:** Encrypts a victim's files, making them inaccessible. The attacker demands a ransom (usually in cryptocurrency) in exchange for the decryption key.
- **Spyware:** Secretly monitors user activity—capturing keystrokes (keyloggers), screenshots, and login credentials—and sends them to the attacker.
- **Adware:** Automatically delivers advertisements to a user. While often just annoying, "Malvertising" can redirect users to malicious sites.

2. Advanced and Emerging Threats

Malware has evolved beyond simple files into sophisticated, stealthy entities.

Fileless Malware

This is a "ghost" in the machine. Instead of installing a file on the hard drive, it lives entirely in the computer's **RAM (Memory)** and uses legitimate system tools (like Windows PowerShell) to carry out attacks. Because there is no file to scan, traditional antivirus often misses it.

Rootkits and Bootkits

- **Rootkits:** Gain administrative (root) access to a system while hiding their presence from the OS.
- **Bootkits:** A type of rootkit that infects the Master Boot Record (MBR), allowing the malware to load *before* the operating system even starts.

3. The Malware Lifecycle

Most modern malware attacks follow a standard "Kill Chain" to achieve their goals:

1. **Delivery:** The malware reaches the target (e.g., via phishing, infected USB, or "drive-by" downloads).
2. **Exploitation:** The malware triggers a vulnerability in the software or user's behavior.
3. **Installation:** The malware establishes a persistent foothold on the device.
4. **Command & Control (C2):** The infected machine "calls home" to the attacker's server for instructions.
5. **Action on Objectives:** The final goal is executed (data theft, encryption, or system destruction).

4. How to Defend Against Malware

A single antivirus isn't enough. You need a multi-layered approach:

- **Endpoint Detection and Response (EDR):** Modern tools that monitor behavior, not just file signatures, to catch "fileless" or "zero-day" (unknown) threats.
- **Sandboxing:** Running suspicious files in an isolated virtual environment to see what they do before allowing them onto the main network.
- **Patch Management:** Keeping software updated to close the "holes" (vulnerabilities) that worms and viruses use to get in.
- **User Training:** Teaching people to spot the "social engineering" tricks used to deliver malware.

PHISHING

The Mechanics of a Phish

Phishing relies on psychological triggers e.g **fear, urgency, curiosity, or authority** to bypass a person's natural skepticism.

The "Hook" (Common Elements)

- **Deceptive Display Names:** The email says "IT Support," but the actual address is `it-support@suspicious-domain.com`.
- **Urgency:** "Your account will be deleted in 2 hours if you don't verify."
- **Malicious Links:** Using URL shorteners or "look-alike" domains (e.g., `microsoft.com` instead of `microsoft.com`).
- **Infected Attachments:** Disguised as "Invoices" or "HR Policy" PDFs that contain macros or malware.

Types of Phishing (The "Tackle Box")

Phishing has evolved from generic mass emails to highly surgical strikes.

Type	Description
Spear Phishing	Highly targeted. The attacker researches the victim (via LinkedIn/Social Media) to include personal details, making the email highly believable.
Whaling	A spear phish directed at "Big Fish" (CEOs, CFOs). These often involve fake legal threats or wire transfer requests.
Vishing	Voice Phishing. Using phone calls or AI-generated "deepfake" voices to impersonate a boss or bank rep.
Smishing	SMS Phishing. Malicious links sent via text message (e.g., "Your package delivery failed, click here").
Angler	Fake social media accounts that "intercept" customers complaining to a real brand to

"help" them by stealing their login.

Technical Analysis: The Phishing Kill Chain

A modern phishing attack isn't just an email; it's a multi-stage technical operation.

1. **Reconnaissance:** Attackers use tools like theHarvester to scrape employee emails and company hierarchies.
2. **Weaponization:** The attacker sets up a **Phishing Kit**. This is a collection of files (HTML, PHP, CSS) that perfectly clones a legitimate login page (like Microsoft 365).
3. **Bypassing MFA:** Advanced phishing kits now use **Reverse Proxies** (like *Evilginx2*).
 - o The victim enters their password on the fake site.
 - o The fake site passes that password to the *real* site.
 - o The real site sends a 2FA code to the victim.
 - o The victim enters the 2FA code on the fake site.
 - o The attacker steals the **Session Cookie**, allowing them to bypass MFA entirely without needing the password ever again.

4. Current Trend: AI-Enhanced Phishing (2025-2026)

In 2026, the game has changed due to Generative AI:

- **Zero Grammar Errors:** Historically, typos were a dead giveaway. Large Language Models (LLMs) now generate perfectly written, professional emails in any language.
- **Scale:** Attackers can generate 10,000 unique, personalized spear-phishing emails in seconds.
- **Deepfake Integration:** Phishing attacks now often include AI-generated video or audio clips of a CEO's voice to authorize "emergency" fund transfers.

5. Defense: Beyond "Just Be Careful"

Because humans are the weakest link, the best defense is a "Zero Trust" technical layer:

- **FIDO2 / Security Keys:** Physical keys (like YubiKeys) are immune to phishing because they only provide the credential if the URL in the browser matches the registered domain.
- **DMARC/SPF/DKIM:** Email authentication protocols that help verify the sender's identity and prevent domain spoofing.
- **Banner Warnings:** Automatically tagging external emails with an **[EXTERNAL]** warning to remind users to be cautious.

AI Threat Detection: Security tools that analyze the *intent* and *tone* of an email rather than just looking for known malicious links.

SOCIAL ENGINEERING

In professional cybersecurity, Social Engineering (SE) is the exploitation of the "Human API." While we spend millions on firewalls and EDR, social engineering bypasses the entire technical stack by compromising the one element that holds administrative privilege: the user.

As a professional, you must view SE not as "tricking people," but as a systematic **exploitation of cognitive biases** to circumvent security controls.

1. The Psychology of the Attack (Cognitive Exploitation)

Social engineers don't just "lie"; they leverage specific psychological triggers to force a target into a state of **System 1 Thinking** (fast, instinctive, emotional) rather than **System 2 Thinking** (slow, logical, analytical).

- **Authority:** Leveraging a hierarchy (e.g., an "urgent" request from a spoofed CEO or a "legal" notice).
- **Urgency & Scarcity:** Creating a high-pressure environment where the victim feels they must act before a "deadline" to avoid a negative consequence (e.g., account suspension).
- **Social Proof/Consensus:** Convincing the victim that "everyone else is doing it" or that a specific action is standard procedure.
- **Likability/Liking:** Building rapport through common interests (often gleaned from OSINT) to lower the target's guard.

2. The Social Engineering Lifecycle

Professional attackers follow a structured framework, similar to the Lockheed Martin Cyber Kill Chain, but focused on human interaction.

1. **Information Gathering (OSINT):** Harvesting data from LinkedIn, social media, corporate directories, and leaked databases.
2. **Relationship Development:** Establishing a pretext. This could be a "new IT guy" introduction or a "potential vendor" inquiry.
3. **Exploitation:** The "ask." Sending the malicious link, requesting a password reset, or asking for a door to be held open.
4. **Execution & Exit:** Achieving the goal (credential harvesting, malware deployment) and closing the interaction without raising suspicion to ensure persistence.

3. Professional Attack Vectors

As a pro, you're likely defending against more than just "spam." You are defending against:

Business Email Compromise (BEC)

A \$50 billion global problem. This involves compromising a high-level executive's email or spoofing it so convincingly that the finance department initiates a wire transfer. It bypasses technical filters because there is often no malware—just a text-based request.

Spear Phishing vs. Whale Phishing

- **Spear Phishing:** Highly targeted at a specific individual or department using OSINT.
- **Whale Phishing:** Specifically targeting the C-Suite (CEO, CFO, CTO) who have the highest levels of access and authorization.

Vishing (Voice Phishing) & Deepfakes

The 2025/2026 landscape is dominated by **AI-driven Vishing**. Attackers use "Deepfake Audio" to clone a manager's voice during a phone call or Zoom meeting. When the "boss" tells you on a live call to bypass MFA for an emergency, standard training often fails.

Tailgating and Piggybacking (Physical SE)

Physically following an authorized person into a restricted area. A professional social engineer might carry a heavy box or a tray of coffees to exploit the target's natural "politeness" to hold the door.

4. Technical Countermeasures for Professionals

Standard "Security Awareness Training" (SAT) is often insufficient. To mitigate professional-grade SE, you need:

Technical Control	Defense Mechanism
FIDO2/WebAuthn	Prevents phishing by requiring a physical hardware key; unlike SMS/TOTP, it cannot be "vished" from a user.
DMARC/SPF/DKIM	Hardens email infrastructure to prevent domain spoofing.
External Email Tagging	Visually identifies emails coming from outside the organization to break the "Authority" bias.
SIEM/UEBA	Using User and Entity Behavior Analytics to detect when a compromised user's account starts acting abnormally (e.g., accessing files at 3 AM).
Export to Sheets	

5. Red Teaming and SE Testing

A mature security posture requires **Social Engineering Penetration Testing**. This involves hiring pros to:

- Perform clandestine physical entries.
- Execute targeted phishing campaigns.
- Call the help desk to attempt unauthorized password resets.

Note on Ethics: Always ensure you have a strict "Rules of Engagement" (RoE) document and a "Get Out of Jail Free" card signed by legal/HR before conducting these tests.

ATTACK VECTOR

In the context of professional cybersecurity, an **attack vector** is the specific path, method, or "route" an adversary takes to gain access to a network or endpoint to deliver a payload or extract data.

To a professional, understanding attack vectors is about mapping the **Attack Surface**—the sum total of all possible points where an unauthorized user can try to enter or extract data from an environment.

1. Classification of Attack Vectors

We generally categorize vectors into three distinct domains based on the "entry point" they exploit.

Technical (Software/Hardware)

These exploit vulnerabilities in code, configurations, or physical hardware.

- **Exploitation of Unpatched Software:** Targeting "Zero-Day" or "N-Day" vulnerabilities (e.g., a buffer overflow in a web server).
- **Credential-Based Attacks:** Brute-forcing, credential stuffing (using leaked passwords), or exploiting weak NTLM hashes.
- **Web-Based Attacks:** SQL Injection (SQLi), Cross-Site Scripting (XSS), or Local File Inclusion (LFI) to bypass application logic.
- **Supply Chain Compromise:** Injecting malicious code into upstream dependencies (libraries, SDKs, or third-party software updates).

Human (Social Engineering)

As discussed, these exploit the "Human API" rather than the silicon.

- **Phishing/Spear-Phishing:** The most common vector for initial access.
- **Pretexting:** Creating a fabricated scenario to steal data (e.g., posing as an auditor).
- **Baiting:** Leaving infected physical media (USB drives) in public areas.

Physical

Direct physical access to the hardware or facility.

- **Unauthorized Hardware:** "Rubber Ducky" HID (Human Interface Device) attacks or network implants (e.g., a Raspberry Pi hidden behind a printer).
- **Console Access:** Gaining physical access to a server or workstation to bypass OS security via BIOS/UEFI manipulation or bootable recovery tools.

2. Professional Vector Analysis: The "Initial Access" Layer

In professional frameworks like **MITRE ATT&CK**, attack vectors are often analyzed through the lens of "Initial Access." Here is how they are currently trending in the 2025/2026 threat landscape:

Attack Vector	Mechanism	Professional Mitigation
API Exploitation	Targeting exposed, unauthenticated, or poorly coded API endpoints.	Implement an API Gateway with mTLS and Rate Limiting.
Living off the Land (LotL)	Using legitimate system tools (PowerShell, WMI) to move laterally.	Advanced behavior-based EDR and strict execution policies.
MFA Bypass	Using "MFA Fatigue" (push bombing) or Session Token Theft (AiTM).	Shift to Phishing-resistant MFA (FIDO2/Passkeys).
Cloud Misconfigurations	Exploiting overly permissive S3 buckets or IAM roles.	Cloud Security Posture Management (CSPM) tools.

Export to Sheets

3. Vulnerability vs. Attack Vector

It is a common mistake to conflate these two. As a professional, you should distinguish them as follows:

- **The Vulnerability:** The hole in the wall (e.g., an unpatched CVE-2024-XXXX).
- **The Attack Vector:** The ladder used to reach the hole (e.g., a remote exploit script delivered over Port 443).

4. Modeling Vectors: The Diamond Model

To analyze attack vectors in depth, professionals use the **Diamond Model of Intrusion Analysis**. It helps correlate the vector with the other three core components of an event:

1. **Adversary:** Who is attacking?
2. **Infrastructure:** What servers/IPs are they using?
3. **Capability:** What tools or malware are they employing?
4. **Victim:** What is the target asset?

The "edges" of the diamond represent the **Attack Vector**—the connection between the adversary's infrastructure and the victim's assets.

5. Modern Shift: The "Identity" Vector

In 2026, the industry consensus is that **"Identity is the new perimeter."** Traditional network vectors (like firewalls) are becoming less relevant as workloads move to the cloud. The primary attack vector is now

increasingly focused on **Identity Provider (IdP) compromise**—if an attacker controls the identity (via SSO or Azure AD/Entra ID), they don't need to "hack" the network; they simply log in.

THREAT ACTOR

In professional cybersecurity, a Threat Actor (or Adversary) is the "who" behind an attack. To a security professional, profiling threat actors is not just about naming groups; it's about understanding their Resources, Constraints, and Intent.

By categorizing actors, we can perform Adversarial Modeling to predict which TTPs (Tactics, Techniques, and Procedures) they are likely to use against our specific stack.

1. The Spectrum of Sophistication

Professionals typically categorize threat actors by their level of "Persistence" and "Resource Depth."

Advanced Persistent Threats (APTs) / Nation-States

These are the apex predators of the digital world, usually government-funded or government-directed.

Motive: Espionage, political disruption, or strategic sabotage (e.g., Stuxnet or SolarWinds).

Capabilities: Unlimited time and budget. They utilize Zero-Day exploits, custom-coded malware, and multi-stage supply chain attacks.

Tactic: Stealth. Their goal is "dwell time"—staying inside a network for months or years without being detected.

Cybercriminal Syndicates (Organized Crime)

The most common adversary for the private sector. They operate like high-growth tech startups.

Motive: Pure financial profit.

Capabilities: High. They often use Ransomware-as-a-Service (RaaS) models where "affiliates" do the hacking and developers provide the tools.

Tactic: Efficiency. They favor high-ROI attacks like Business Email Compromise (BEC) and Big Game Hunting (targeting large corporations for massive ransoms).

Hacktivists

Individuals or groups acting on behalf of a cause (political, social, or religious).

Motive: Publicity, ideology, or social change (e.g., Anonymous).

Capabilities: Variable. Often use lower-tier methods like DDoS attacks or website defacement to gain attention.

Tactic: Visibility. Unlike APTs, they want you to know you've been hit.

Insider Threats

The "Call is Coming from Inside the House."

Malicious Insider: A disgruntled or bribed employee who uses their legitimate access to steal data or sabotage systems.

Negligent Insider: An employee who bypasses security controls for "convenience" or accidentally leaks data (the "oops" factor).

Capabilities: Unique. They don't need to "break in"; they already have the keys.

2. Professional Comparison: Threat Actor Profiles

Actor Type	Resource Level	Typical Dwell Time	Primary Threat to You
Nation-State	Massive (State-funded)	Years	IP Theft, Espionage
Cybercriminal	High (Profit-funded)	Weeks/Days	Ransomware, Data Extortion
Hacktivist	Moderate (Crowdsourced)	Hours/Days	Service Disruption (DDoS)
Insider	N/A (Internal Access)	Indefinite	Data Exfiltration
Script Kiddie	Low (Public Tools)	Minutes	Opportunistic Defacement

3. The "Identity Convergence" Trend (2025/2026)

A critical shift in the current landscape is the convergence of state-sponsored and criminal actors.

Proxy Groups: Some nation-states (like North Korea) use cybercriminal tactics (bank heists, crypto-theft) to fund their government.

False Flags: State actors often use common ransomware code to make an attack look like a simple criminal extortion attempt, hiding their true political or destructive intent.

Shutterstock

4. How Professionals Use This Intel

As a defender, knowing your actor changes your Monitoring Strategy:

If the actor is a Nation-State: You look for "Low and Slow" anomalies in outbound traffic (Exfiltration) and focus on Supply Chain Integrity.

If the actor is a Cybercriminal: You prioritize MFA, RDP hardening, and rapid Patch Management to close common entry points.

If the actor is an Insider: You focus on UEBA (User and Entity Behavior Analytics) to flag when a user suddenly downloads a 50GB database they've never accessed before.

5. Threat Modeling: The "Persona" Approach

In professional environments, we often create Threat Personas for our specific organization.

Example: If you work in a hospital, your "Primary Threat Persona" is likely an Organized Crime Group focused on high-availability ransomware.

Example: If you work for a Defense Contractor, your "Primary Threat Persona" is a Nation-State APT focused on stealthy IP theft.

INTRODUCTION TO SECURITY FRAMEWORKS

NIST FRAMEWORK

The **NIST Cybersecurity Framework (CSF)** is essentially the "gold standard" playbook for managing and reducing cybersecurity risk. Developed by the National Institute of Standards and Technology, it's designed to be flexible enough for a small tech startup but robust enough for a massive government agency.

Think of it as a common language that helps IT experts and business executives stay on the same page.

The Core Pillars (CSF 2.0)

In early 2024, NIST updated the framework to version 2.0. The most significant change was the addition of the **Govern** function, emphasizing that cybersecurity isn't just a technical problem—it's a leadership responsibility.

The framework is organized into six concurrent and continuous functions:

1. Govern (GV)

This is the new "north star." It focuses on establishing the organization's cybersecurity strategy, expectations, and policy. It ensures that the other five functions are aligned with the business's goals and legal requirements.

2. Identify (ID)

Before you can protect anything, you have to know what you have. This stage involves cataloging:

- **Physical Devices:** Laptops, servers, IoT devices.
- **Software:** Apps and platforms.
- **Data:** Where the sensitive stuff lives.

3. Protect (PR)

These are your proactive defenses. The goal is to limit or contain the impact of a potential cybersecurity event.

- **Access Control:** Ensuring only the right people get in (MFA, password policies).
- **Awareness Training:** Teaching employees not to click on shady links.
- **Data Security:** Encryption and backups.

4. Detect (DE)

You can't stop what you can't see. This function focuses on identifying when a "cybersecurity event" is happening in real-time.

- **Monitoring:** Looking for weird spikes in network traffic.
- **Maintenance:** Keeping logs of who accesses what.

5. Respond (RS)

When an incident is detected, this is the "fire drill" phase. It's about taking action to contain the damage.

- **Analysis:** Figuring out what happened.

- **Mitigation:** Neutralizing the threat (e.g., disconnecting an infected server).
- **Communication:** Notifying stakeholders and law enforcement if necessary.

6. Recover (RC)

The goal here is resilience—getting back to business as usual as quickly as possible.

- **Recovery Planning:** Executing the "Plan B."
- **Improvements:** Learning from the attack so it doesn't happen again.

Cybersecurity Framework (CSF) Overview

This document is version 2.0 of the NIST Cybersecurity Framework (Framework or CSF). It includes the following components:

- **CSF Core**, the nucleus of the CSF, which is a taxonomy of high-level cybersecurity outcomes that can help any organization manage its cybersecurity risks. The CSF Core components are a hierarchy of Functions, Categories, and Subcategories that detail each outcome. These outcomes can be understood by a broad audience, including executives, managers, and practitioners, regardless of their cybersecurity expertise. Because the outcomes are sector, country, and technology-neutral, they provide an organization with the flexibility needed to address its unique risks, technologies, and mission considerations.
- **CSF Organizational Profiles**, which are a mechanism for describing an organization's current and/or target cybersecurity posture in terms of the CSF Core's outcomes.
- **CSF Tiers**, which can be applied to CSF Organizational Profiles to characterize the rigor of an organization's cybersecurity risk governance and management practices. Tiers can also provide context for how an organization views cybersecurity risks and the processes in place to manage those risks.

An organization can use the CSF Core, Profiles, and Tiers with the supplementary resources to understand, assess, prioritize, and communicate cybersecurity risks.

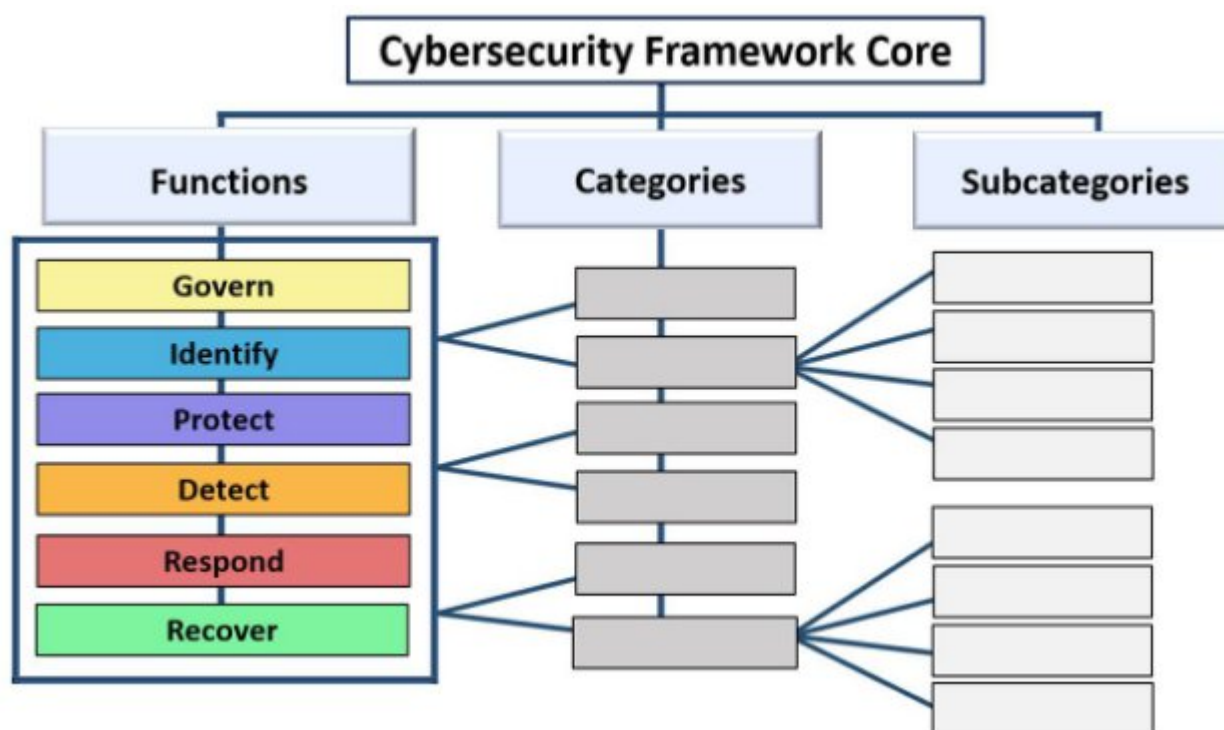
- **Understand and Assess:** Describe the current or target cybersecurity posture of part or all of an organization, determine gaps, and assess progress toward addressing those gaps.
- **Prioritize:** Identify, organize, and prioritize actions for managing cybersecurity risks that align with the organization's mission, legal and regulatory requirements, and risk management and governance expectations.
- **Communicate:** Provide a common language for communicating inside and outside the

organization about cybersecurity risks, capabilities, needs, and expectations.

2. Introduction to the CSF Core

CSF Core — a set of cybersecurity outcomes arranged by Function, then

Category, and finally Subcategory, as depicted in Fig. 1. These outcomes are not a checklist of actions to perform; specific actions taken to achieve an outcome will vary by organization and use case, as will the individual responsible for those actions. Additionally, the order and size of Functions, Categories, and Subcategories in the Core does not imply the sequence or importance of achieving them. The structure of the Core is intended to resonate most with those charged with operationalizing risk management within an organization.



The CSF Core Functions GOVERN, IDENTIFY , PROTECT , DETECT , RESPOND , and RECOVER — organize

cybersecurity outcomes at their highest level.

- **GOVERN (GV)** — The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored. The GOVERN Function provides outcomes to inform what an organization may do to achieve and prioritize the outcomes of the other five Functions in its mission and stakeholder expectations. Governance activities are critical for incorporating cybersecurity into an organization's broader enterprise risk management (ERM) strategy. GOVERN addresses an understanding of organizational context; the

establishment of cybersecurity strategy and cybersecurity supply chain risk management; roles, responsibilities, and authorities; policy; and the oversight of cybersecurity strategy.

• **IDENTIFY (ID)**

Understanding the organization's assets (e.g., data, hardware, software, systems, facilities, services, people), suppliers, and related cybersecurity risks enables an organization to prioritize its efforts consistent with its risk management strategy and the mission needs identified under GOVERN. This Function also includes identification of improvement opportunities for organization's policies, plans, procedures, and practices supporting cybersecurity risk management to inform efforts under all six Functions.

PROTECT (PR) — Safeguards to manage the organization's cybersecurity risks are used.

Once assets and risks are identified and prioritized, PROTECT supports the ability to secure those assets to prevent or lower the likelihood and impact of adverse cybersecurity events, as well as to increase the likelihood and impact of taking advantage of opportunities. Outcomes covered by this Function include identity management, authentication, and access control; awareness and training; data security; platform security (i.e., securing the hardware, software, and services of physical and virtual platforms); and the resilience of technology infrastructure.

DETECT (DE) — Possible cybersecurity attacks and compromises are found and analyzed.

DETECT enables the timely discovery and analysis of anomalies, indicators of compromise, and other potentially adverse events that may indicate that cybersecurity attacks and incidents are occurring. This Function supports successful incident response and recovery activities.

RESPOND (RS) — Actions regarding a detected cybersecurity incident are taken. RESPOND supports the ability to contain the effects of cybersecurity incidents. Outcomes within this Function cover incident management, analysis, mitigation, reporting, and communication.

RECOVER (RC) — Assets and operations affected by a cybersecurity incident are restored.

RECOVER supports the timely restoration of normal operations to reduce the effects of cybersecurity incidents and enable appropriate communication during recovery efforts.



The Functions should be addressed concurrently. Actions that support GOVERN, IDENTIFY, PROTECT, and DETECT should all happen continuously, and actions that support RESPOND and RECOVER should be ready at all times and happen when cybersecurity incidents occur. All Functions have vital roles related to cybersecurity incidents. GOVERN, IDENTIFY, and PROTECT outcomes help prevent and prepare for incidents, while GOVERN, DETECT, RESPOND, and RECOVER outcomes help discover and manage incidents.

The Functions, Categories, and Subcategories apply to all ICT used by an organization, including information technology (IT), the Internet of Things (IoT), and operational technology (OT). They also apply to all types of technology environments, including cloud, mobile, and artificial intelligence systems. The CSF Core is forward-looking and intended to apply to future changes in technologies and environments.

3. Introduction to CSF Profiles and Tiers

3.1. CSF Profiles

A CSF Organizational Profile describes an organization's current and/or target cybersecurity posture in terms of outcomes. They are used to understand, assess, and communicate the Core's outcomes by considering an organization's mission objectives, stakeholder expectations, threat landscape, and requirements.

Every Organizational Profile includes one or both of the following:

1. **A Current Profile** specifies the Core outcomes that an organization is currently achieving (or attempting to achieve) and how or to what extent each outcome is

being achieved.

2. A **Target Profile** specifies the desired outcomes that an organization has selected and prioritized for achieving its cybersecurity risk management objectives. A Target Profile anticipates changes to the organization's cybersecurity posture, such as new requirements, new technology adoption, and threat intelligence trends.



1. **Scope the Organizational Profile.** Document facts and assumptions on which to base the Profile to define its scope.

For example, a Profile could address an entire organization or be scoped to an organization's financial systems or countering ransomware threats and handling ransomware incidents involving those financial systems.

2. **Gather the information needed to prepare the Organizational Profile.** Information may include organizational policies, risk management priorities & resources, enterprise, Business Impact Analysis, cybersecurity requirements and standards, practices, tools, and work roles.

3. **Create the Organizational Profile.** Determine what types of information the Profile should include for the selected CSF outcomes, and document it.

Consider risk implications of Current Profile to inform Target Profile planning and prioritization. Also, consider using a Community Profile as the basis for the Target Profile.

4. **Analyze the gaps between the Current and Target Profiles, and create an action plan.**

Conduct a gap analysis to identify & analyze the differences between the Current and Target Profiles, and develop a prioritized action plan (e.g., risk register, risk detail report, Plan of Action and Milestones [POA&M]) to address those gaps.

5. **Implement the action plan, and update the Organizational Profile.** Follow the action plan to address gaps and move the organization toward the Target Profile. An action plan may have an overall deadline or be ongoing.

3.2. CSF Tiers

An organization can choose to use Tiers to inform its Current and Target Profiles. Tiers characterize the rigor of an organization's cybersecurity risk governance and management practices, and provide context for how an organization views cybersecurity risks and the processes in place to manage those risks. The Tiers, reflect an organization's practices for managing cybersecurity risk as Partial (Tier1), Risk Informed (Tier 2), Repeatable (Tier 3), and Adaptive (Tier 4). The Tiers describe a progression from informal responses to approaches that are risk-informed, and continuously improving.



Tiers should complement an organization's cybersecurity risk management methodology rather than replace it. For example, an organization can use Tiers to communicate internally as a benchmark for an organization-wide approach to managing cybersecurity risks.

5. Improving Cybersecurity Risk Communication and Integration

The CSF's use will vary based on an organization's unique mission and risks. With an understanding of stakeholder expectations and risk tolerance (as outlined in GOVERN), an organization can prioritize cybersecurity activities to make informed decisions about cybersecurity expenditures and actions. An organization may choose to handle risk in one or more ways — including accepting negative risks depending on the potential impacts and likelihoods.

An organization may benefit from using the CSF as guidance to help it understand, assess, prioritize, and communicate cybersecurity risks and the actions that will manage those risks. The selected outcomes can be used to implement strategic decisions to improve cybersecurity postures and maintain continuity of mission essential functions while taking priorities and available resources into account.

SIMPLE CYBER SECURITY RISK ASSESSMENT TEMPLATE

RISK RATING KEY	LOW	MEDIUM	HIGH	EXTREME
	ACCEPTABLE	1 ALARP (as low as reasonably practicable)	2 GENERALLY UNACCEPTABLE	3 INTOLERABLE
	OK TO PROCEED	TAKE MITIGATION EFFORTS	SEEK SUPPORT	PLACE EVENT ON HOLD

	SEVERITY			
	ACCEPTABLE LITTLE TO NO EFFECT ON EVENT	TOLERABLE EFFECTS ARE FELT, BUT NOT CRITICAL TO OUTCOME	UNDESIRABLE SERIOUS IMPACT TO THE COURSE OF ACTION AND OUTCOME	INTOLERABLE COULD RESULT IN DISASTER
LIKELIHOOD				
IMPROBABLE RISK IS UNLIKELY TO OCCUR	LOW – 1 –	MEDIUM – 4 –	MEDIUM – 6 –	HIGH – 10 –
POSSIBLE RISK WILL LIKELY OCCUR	LOW – 2 –	MEDIUM – 5 –	HIGH – 8 –	EXTREME – 11 –
PROBABLE	MEDIUM	HIGH	HIGH	EXTREME

RISK WILL OCCUR	- 3 -	- 7 -	- 9 -	- 12 -
-----------------	-------	-------	-------	--------

RISK RATING KEY	LOW	MEDIUM	HIGH	EXTREME
	ACCEPTABLE	1 ALARP (as low as reasonably practicable)	2 GENERALLY UNACCEPTABLE	3 INTOLERABLE
	OK TO PROCEED	TAKE MITIGATION EFFORTS	SEEK SUPPORT	PLACE EVENT ON HOLD

	SEVERITY			
	ACCEPTABLE LITTLE TO NO EFFECT ON EVENT	TOLERABLE EFFECTS ARE FELT, BUT NOT CRITICAL TO OUTCOME	UNDESIRABLE SERIOUS IMPACT TO THE COURSE OF ACTION AND OUTCOME	INTOLERABLE COULD RESULT IN DISASTER
LIKELIHOOD				
IMPROBABLE RISK IS UNLIKELY TO OCCUR	LOW - 1 -	MEDIUM - 4 -	MEDIUM - 6 -	HIGH - 10 -
POSSIBLE RISK WILL LIKELY OCCUR	LOW - 2 -	MEDIUM - 5 -	HIGH - 8 -	EXTREME - 11 -
PROBABLE	MEDIUM	HIGH	HIGH	EXTREME

WIRESHARK

USES

- Live packet capture.
- Analyzing data from other interception tools.
- Import and analyze hex dumps.
- Export data in different formats.
- Detailed packet analysis.
- Working with statistics.
- Decoding encrypted data.

*Remember to work on promiscuous mode as well. In the case of traffic not meant for your device.